

ASSIGNMENT-03.

NAME : DINDU PUJITHA.

REG NO : 192373037.

COURSE CODE : CSA5113.

COURSE NAME : CRYPTOGRAPHY.

88
100
②

A system uses HMAC with SHA-256 to authenticate messages b/w a client and a server.

a) what is the purpose of HMAC over plain hash functions?

HMAC (Hash-based message Authentication code) provides both message integrity and authentication using a secret key.

A plain hash function such as SHA-256 only produces a hash of the message. Anyone can calculate the hash, so it does not prove who sent the message.

$$\text{HMAC} = \text{Secret Key} + \text{Hash function} + \text{Message}.$$

Therefore, HMAC Ensures;

- * The message has not been modified.
- * The message was generated by someone who knows the secret key.
- * An attacker cannot easily create a valid HMAC without knowing the key.

b. Given :

- Message = "HELLO"
- Key = "SECRET"

• Hash used = SHA-256
Explain (in steps) how HMAC will be calculated.

Given:

Message = "HELLO"

Key = "SECRET"

Hash = SHA-256

HMAC-SHA-256 is calculated using the standard

HMAC formula:-

$$\text{HMAC}(K, M) = H((K' \oplus \text{opad}) \parallel H((K' \oplus \text{ipad}) \parallel M))$$

Where:-

K = secret key (SECRET)

M = message (HELLO)

H = SHA-256

ipad = inner padding

opad = outer padding

$\oplus$ = XOR

$\parallel$ = concatenation.

Steps: convert the key and message into bytes

Key = SECRET

Message = HELLO

Prepare the key

SHA-256 has a block size of 64 bytes.

The key SECRET is shorter than 64 bytes, so

it is padded with zeros to make it 64 bytes

create the inner key.

XOR the padded key with the constant ipad
(0x36)

calculate the inner hash:

Inner Hash = $\text{SHA-256}((\text{padded key} \oplus \text{ipad}) \parallel \text{HELLO})$

create the outer key.

XOR the padded key with the constant opad (0x5c)

calculate the final HMAC:

$\text{HMAC} = \text{SHA-256}((\text{padded key} \oplus \text{opad}) \parallel \text{Inner Hash})$

The resulting 256-bit (32-byte) value is the HMAC authentication code.

thus, the client sends the message along with its HMAC. The server uses the same secret key to calculate the HMAC and compares the results. If they match, the message is considered authentic and unchanged.

c) why is it not advisable to use MD5 in HMAC for security-critical applications?

MD5 is not recommended because it has well-known collision vulnerabilities.

An attacker can construct different messages that produce the same MD5 hash.

Although HMAC-MD5 is more resistant to some attacks than plain MD5, MD5 is still considered cryptographically weak and unsuitable for new

security - critical systems.

d). How does a MAC differ from a digital signature in terms of authentication and non-repudiation?

Feature	MAC	Digital Signature	Keys used
Authentication	Yes	Yes	
Integrity	Yes	Yes	
Non-repudiation	No	Yes	
Verification	Anyone with the shared key	Anyone with the public key	

Example:-

HMAC - SHA-256 RSA / ECDSA signature.

MAC:-

Both sender and receiver possess the same secret key. Since both know the key, the receiver cannot prove to a third party that only the sender created the MAC.

Therefore, MAC does not provide non-repudiation.

Digital signature :

The sender signs the message using a private key, and the receiver verifies it using the sender's public key. Since the private key is controlled by the signer, digital signatures provide authentication, integrity, and non-repudiation.

② ——— * * * ———